

Security Measure Plan for VMware vSphere 6

Version 1.0
2017-03-31
Restricted

Restricted
Document Owner: Siemens Governance Information Security and
Product & Solution Security
governance.infosec_pss@siemens.com
Siemens AG, CT RDA SEG
Otto-Hahn-Ring 6
81739 Munich
Germany

Edited by: Christian Koepp
Siemens AG, CT RDA ITS CER
Otto-Hahn-Ring 6
81739 Munich
Germany

Please write your comments to governance.infosec_pss@siemens.com.
© 2017 by Siemens AG

Table of Contents

1	Document Release and History	5
1.1	Document Release	5
1.2	Document History	5
1.3	Changes in Version 1.0	6
1.4	Document Maintenance	6
2	Introduction	7
2.1	Scope	7
2.2	Deployment Planning	7
2.3	Requirement Level Definition	8
2.4	Categorization of Measures	8
2.5	Readability	9
2.6	Regulatory and Corporate Obligations	9
3	General Security Principles	11
3.1	Follow Siemens Information Security Framework	11
3.2	Compliance with Corporate Password Policy	12
3.3	Siemens CERT Security Telegrams and Update Policy	14
3.4	Implement Relevant CERT Measure Plans	15
3.5	Principle of Least Privilege	16
3.6	Avoid Granting Privileges to Single Users	17
3.7	Use Siemens PKI Certificates	18
3.8	Protecting Physical Interfaces	20
3.9	Secure Built-in Remote Management Interface	21
3.10	Configure NTP Clients	23
3.11	Enable Persistent Logging	24
3.12	Prevent Resource Takeover	26
4	General Network Security	27
4.1	Separate Management and User Networks	27
4.2	Secure vMotion Network Traffic	29
4.3	Check Network Isolation at Regular Intervals	30
4.4	Disable Native VLAN Feature for All Switches	31
4.5	Disable Simple Network Management Protocol	32
4.6	Reject Forged Transmissions from Virtual Machines	33
4.7	Disable Promiscuous Mode for Virtual Network Interfaces	34
5	vCenter Security	35
5.1	Enable Network File Copy Encryption	35
5.2	Use Active Directory Service for Authentication	36
5.3	Limit vCenter Server Network Connectivity	37
5.4	Install a Dedicated vCenter Account	38
5.5	Remove vSphere Administrator Privileges from Domain Admins	39
5.6	Do Not Grant vSphere Access for Users of Virtual Machines	40
5.7	Secure vCenter Single Sign On	41

6	ESXi Security	43
6.1	Enable lockdown mode	43
6.2	Enable ESXi Firewall	44
6.3	Control CIM-based Hardware Monitoring Tool Access	45
6.4	Do Not Use the Root User	46
6.5	Disable ESXi Privileges for AD Group "ESX Admins"	47
6.6	Only Use Drivers from Trusted Sources	48
6.7	Secure Storage Traffic	49
6.8	Secure the ESXi Shell	50
6.9	Disable Managed Object Browser	52
6.10	Centralized Collection of Core Dumps	53
6.11	Prevent Unintended Usage of dvfilter API	54
7	Virtual Machine Security	55
7.1	Disable Copy-and-Paste and Drag-and-Drop Operations	55
7.2	Disable Shared Console Sessions	57
7.3	Disable Unused Display Features	58
7.4	Disable Unity Features	59
7.5	Disable Unexposed VMX Features	61
7.6	Disable VIX Messages from Virtual Machines	63
7.7	Limit Host Information Sharing	64
7.8	Reject MAC Address Changes by Virtual Machines	65
7.9	Limit Information Messages Stores Within VMX Files	66
7.10	Limit Log File Numbers and Size for Virtual Machines	67
7.11	Prevent Virtual Disk Operations	69
7.12	Secure Connected Devices	70
7.13	Restrict Import of Virtual Machines in Native Format	72
7.14	Patching of Inactive Virtual Machines and Templates	73
7.15	Snapshot Documentation and Removal	75
8	Miscellaneous	76
8.1	Secure Update Manager	76
9	Checklist	77
	References	80

1 Document Release and History

1.1 Document Release

This document is classified as "Restricted". Version 1.0 has been given the status "released".

	Name	Operating Group	Date
Author	Christian Koepp	CT RDA ITS CER	2017-03-31
Reviewer	Matthias Dominick	CT RDA SEG	2017-03-31
Release Governance Information Security		CT RDA SEG	2017-03-31

1.2 Document History

Version	Name	Operating Group	Date
V 0.9	Christian Koepp	CT RDA ITS CER-DE	2017-01-31
V 1.0	Christian Koepp	CT RDA ITS CER-DE	2017-03-31

1.3 Changes in Version 1.0

Note: As this is the first binding release of the Security Measure Plan for VMware vSphere 6 **all measures** have the **EVAL** flag set.

The following measures/sections have been changed after the review phase:

- **M135274 Prevent Resource Takeover**
Specified *Measure* and *Implementation* section.
- **M135863 Enable ESXi Firewall**
Specified *Measure* and *Explanation* section for better understanding.
- **M135825 Centralized Collection of Core Dumps**
Limited the measure to specific ACP levels in order to avoid core dumps for non-critical system; removed the *Exception* section.
- **M135342 Prevent Unintended Usage of dvfilter API**
Added more use cases for dvfilter API to the *Exception* section.
- **M135621 Disable Unity Features**
Updated *Measure* section in order to limit measure to guests intended for client-export.
- **M135565 Disable Unexposed VMX Features**
Updated *Measure* section in order to limit measure to guests intended for client-export.

1.4 Document Maintenance

Release dates for updates of CERT Measure Plans are the end of May and the end of November of each year. However, CERT Measure Plans will only be updated if significant changes require a new release. Hence, there might not always be a new release of every CERT Measure Plan on every release date. Any update will be announced via a CERT Security Telegram of category "Governance". For a detailed description of the release process see <https://www.cert.siemens.com/rules#process>.

The information herein has been compiled to our best knowledge and testing. To further improve its quality, we depend on your feedback and opinion. Please send any comments or suggestions via e-mail to governance.infosec_pss@siemens.com.

2 Introduction

The "Security Measure Plan for VMware vSphere 6" document is a platform specific supplement to the ISEC Technical Standards of the *Siemens Information Security Framework* [2] and other existing Siemens CERT Security Measure Plans. Its purpose is increased intrusion security for IT systems and it must be implemented in all Siemens units. The measures and their priorities described here may be tightened and supplemented as necessary.

The Security Measure Plan is published by Siemens CERT as part of the ISEC Technical Standards of the *Siemens Information Security Framework* [2] on behalf of Siemens *Governance Information Security and Product & Solution Security*.

To assist in documentation, a checklist (see [Chapter 9](#)) was prepared in addition to the Security Measure Plan. The checklist can be used to document the implementation of the individual measures of this Security Measure Plan.

2.1 Scope

This document is a Security Measure Plan that describes measures to be taken in order to enhance VMware vSphere security. Concerning VMware vSphere, several components have to be considered. In detail, these components are:

- ESXi Server,
- vCenter Server,
- Update Manager,
- Virtual Machines.

The following optional components and extensions are out of scope of this Measure Plan:

- Add-ons and plugins for VMware products from third party suppliers,
- Virtual appliances from third party suppliers,
- vCloud components like vCloudDirector,
- Desktop virtualization products like VMware Desktop,
- Virtualization infrastructure other than official vSphere components.

2.2 Deployment Planning

Deploying a vSphere installation requires careful planning of several different aspects. In terms of security, this is especially important. This Measure Plan contains several measures which should be considered during the planning phase, otherwise it might be difficult to implement them later on.

The following enumeration lists additional measures that should be considered at an early stage of a vSphere installation project:

- Definition of scope and purpose of the vSphere installation,
- Definition of roles and responsibilities for administrators and users,

- Definition of intended user groups and required privileges,
- Definition, separation, and setup of frontend and backend networks,
- Definition and implementation of physical access control to the vSphere installation,
- Definition and implementation of an update and patch process for vSphere components and virtual machines.

2.3 Requirement Level Definition

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119 (see <https://www.ietf.org/rfc/rfc2119.txt>).

2.4 Categorization of Measures

All measures in this document are categorized as **MANDATORY**. This categorization means that implementation is absolutely required. If implementation is impossible, a system must not be connected to the Siemens intranet. Exceptions other than those explicitly declared inside a measure require approval by a CISO-level representative of ISEC (e.g., exceptions for Research & Development purposes).

If a new measure is added or an existing measure is upgraded, it receives the additional flag **EVAL** – with the exception of very time-critical cases. The use of the **EVAL** flag signifies:

‘This measure has an evaluation period of three months plus an implementation grace period of one month before it must be implemented on all affected systems. The end date of the evaluation period is clearly stated next to the unique measure number: (e.g., **EVAL** flag expires 2010-01-30). Within the three month evaluation period Siemens units and service providers are requested to pilot this measure and to report any problems to governance.infosec_pss@siemens.com.’

New or upgraded measures without an **EVAL** flag are considered time-critical. Such measures must be implemented within one month after release. Should it turn out – as a result of the three months evaluation period – that the measure cannot be implemented as expected, Siemens CERT will communicate appropriate actions via a Security Telegram of category "Governance". Therefore please check our webpage at <https://www.cert.siemens.com/sectel/gov> to determine whether a measure marked with **EVAL** has not become binding.

2.5 Readability

By default, all measures have the same structure according to heading, measure, explanation and implementation sections:

chapter number	measure name	unique measure number	category	evaluation flag
3.1.12	Measure name			EVAL
				mandatory

Measure Mxxxxxx, created/modified/revised on yyyy-mm-dd.
EVAL flag expires yyyy-mm-dd.

Explanation

<Motivation and background information for this measure>

Measure

<General description of what needs to be done>

Implementation

<Detailed information about how to implement this measure>

Note: The implementation section given for a measure provides guidance for implementation, i.e., it does not prescribe a way in which the measure must be implemented. Alternative implementations that also satisfy the measure therefore are possible.

2.6 Regulatory and Corporate Obligations

Regulatory and corporate obligations support achieving contractual and legal compliance but assist as well in the handling of Information Security incidents. While not each obligation may be applicable for every system/application at the time of writing, this may change in the future. Therefore, a web site is listed for every topic to find further information as well as contact persons who can assist you in case of questions. Please note that the obligations may also apply to virtual systems and applications running on virtualized hardware.

Compliance: Some of the measures mentioned in this document might affect current Compliance regulations, especially regarding the effective circulars concerning the storage of certain compliance-relevant data.

Compliance web site: <https://intranet.siemens.com/en/compliance/>.

Asset Classification & Protection: To protect assets adequately according to their criticality it is necessary to identify these assets based on a standardized process, classify the assets, implement appropriate protection concepts and document this in a central tool (as specified by *Siemens Circular No. 156 [14]*).

This includes all tangible and intangible assets and therefore may also apply to IT Applications and Infrastructure, which are subject of this measure plan. Please note, that if several applications are hosted or run on one server system, the application with the highest criticality determines the criticality of the server system.

GM SEC web site "Asset Classification & Protection (ACP)": <https://intranet.siemens.com/asset-classification/>.

Documentation of the IT landscape: Networks, systems and applications shall be sufficiently documented and kept up to date in the appropriate IT repositories.

If those IT repositories do not apply to a system or infrastructure component or application, at least a documentation of the owner of the infrastructure and owner of the application(s) shall be maintained.

Siemens IT web site "IT Repositories": <https://cio.siemens.com/cms/it/en/governance/Pages/gov-lpd.aspx>.

Inventory Infrastructure "SAM@Siemens": Systems which are supported by the "SAM@SIEMENS" Inventory Tools need to establish a connection to the Inventory Infrastructure "SAM@Siemens" to ensure the compliant handling of license inventory data.

Siemens IT web site "Software Asset Management (SAM)": <https://cio.siemens.com/sam/>.

3 General Security Principles

3.1 Follow Siemens Information Security Framework

EVAL

mandatory

Measure M135365, created on 2017-03-31. EVAL flag expires 2017-06-30.

Explanation

This Measure Plan is a platform specific supplement to the Siemens Information Security Framework [2]. The framework contains several policies that regulate the IT landscape of Siemens and that are binding for service users and service providers. In addition to measures of this document, you must follow other relevant regulations and policies of the Siemens Information Security Framework. An overview of the Siemens Information Security Framework can be found at <http://intranet.siemens.com/ISECFramework>.

As a provider or user of virtual network and server infrastructure, you should pay special attentions to regulations regarding:

- Protection of corporate information
(*Topic-Specific ISEC Policy: Asset Management*, [4]),
- Secure network topology
(*ISEC Technical Standard: Secure Network Topologies - Network Zone Types*, [1]),
- Security of web-based communications
(*Topic-Specific ISEC Policy: Access Control*, [3]),
- Data backup
(*Topic-Specific ISEC Policy: Operations Security*, [6]).

Measure

Follow relevant policies from the Siemens Information Security Framework.

Implementation

N/A

Revision history:

- 1.0: Measure created.

3.2 Compliance with Corporate Password Policy

EVAL

mandatory

Measure M135290, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Weak passwords form a major threat to any IT system. By using brute force attacks an intruder might be able to guess weak passwords within a short span of time. Thus, a corporate password policy exists to provide a framework for secure password-based authentication processes.

For all password authentication processes used within a vSphere infrastructure, it must be ensured that the password policy for users is in compliance with the *Topic-Specific ISEC Policy: Access Control*, [3].

Measure

Wherever password-based authentication processes are used, compliance with the *Topic-Specific ISEC Policy: Access Control*, [3] must be enforced.

Implementation

Implement the password rules that are listed in the *Topic-Specific ISEC Policy: Access Control*, [3] within all components that are part of the vSphere infrastructure.

Siemens CERT recommends to use the Siemens' Active Directory (AD) infrastructure as identity database. Authentication processes using the Siemens AD are compliant to the corporate password policy by default.

Applying password policy upon ESXi hosts

The ESXi password policy is enforced for direct access from the direct console UI (DCUI), the ESXi shell, SSH, and the vSphere Client. Thus, adopting the Siemens policy upon ESXi hosts is an essential step for every policy-compliant vSphere infrastructure. Follow these actions to enforce the current Siemens Password Policy:

1. Connect to the vCenter Server and select an ESXi host,
2. Select *Settings* → *Advanced Settings* → *Edit*,
3. Set *Security.PasswordQualityControl* to a value of *retry=3 min=disabled,disabled,disabled,disabled,20*
4. Click OK to apply the change.

Doing so enforces new passwords to be at least 20 characters long and to include four different character types. The *retry* argument ensures that a wrong password can be entered three times before the authentication process will fail. Note that the new policy is only applied to new passwords. Already existing passwords need to be changed manually in order to match the new requirements.

Applying password policy upon vServer Single Sign On

Log in to the vSphere Web Client using an account with vCenter Single Sign On administrator privileges. This account is different from the vSphere Administrator account and often called *admin@system-domain*. To set the password policy for standard user accounts follow these steps:

1. Select *Administration* → *Sign-On and Discovery* → *Configuration*,
2. Select *Password Policy* in the *Policy* tab,
3. Click edit and set the following parameter values

Maximum lifetime	90	
Restrict re-use	5	
Minimum length	8	
Character requirements	Special	1
	Alphabetic	2
	Uppercase	1
	Lowercase	1
	Numeric	1

A maximum lifetime of 365 days may only be used for service accounts as defined in the *Topic-Specific ISEC Policy: Access Control*, [3]. The maximum lifetime of passwords for administrative users is 30 days.

Applying password policy upon other components

Please consult the corresponding vendor manuals.

Revision history:

- 1.0: Measure created.

3.3 Siemens CERT Security Telegrams and Update Policy

EVAL

mandatory

Measure M135739, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Outdated software forms a major threat to IT systems. Due to this, keeping a system up-to-date is a crucial part of the maintenance process for running systems.

Security Telegrams are a service provided by Siemens CERT company-wide and free of charge. A telegram is issued whenever there is a known vulnerability of the supported operating systems or applications for which a workaround or patch is available. Typically, a telegram also contains a description of the vulnerability, affected platforms and links to further information. Telegrams are delivered through eMail after subscription at <https://www.cert.siemens.com/sectel/subscribe>. A list of all prior released security telegrams is available on the Siemens CERT web server at <https://www.cert.siemens.com/sectel/>.

Please note that Siemens CERT provides separate Security Measure Plans and checklists for most components used in a typical vSphere installation. However, your vSphere infrastructure might use services, add-ons or other component that are not officially supported by Siemens CERT. Naturally, these products must also be kept up-to-date.

Measure

Make sure to receive all relevant Security Telegrams for components used within your vSphere infrastructure. Apply the measures from Siemens CERT Security Telegrams relevant to your specific system configuration within the time frame given by the telegram.

If no Security Telegram Service for components within your vSphere infrastructure is offered by Siemens CERT, make sure to receive security advisories and patch announcements from the corresponding vendors. Apply the measures outlined by the vendors within a reasonable timescale.

Implementation

In case the VMware Software Update Manager is used in the installation, there should be a baseline containing all security patches for the ESXi hosts and other software components. This baseline should be updated in regular intervals and checked against all vSphere components. Be aware that not every add-on for vSphere is supported by VMware Update Manager. Thus, a manual installation of patches might be needed for certain software components.

Additionally, Siemens CERT strongly encourages vSphere administrators to read the VMware Security Response Policy, which is available through https://www.vmware.com/support/policies/security_response.html.

Revision history:

- 1.0: Measure created.

3.4 Implement Relevant CERT Measure Plans

EVAL

mandatory

Measure M135517, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

A typical vSphere 6 system incorporates the following components:

1. One or multiple physical ESXi hosts,
2. Microsoft Windows guest operating systems,
3. Unix/Linux guest operating systems,
4. Inventory/configuration database server,
5. Network infrastructure,
6. Storage systems.

Siemens CERT provides separate security Measure Plans and checklists [7] for these components.

Measure

Download the latest version of each relevant Measure Plan from the CERT website at <https://www.cert.siemens.com/rules> and implement them accordingly.

Implementation

All virtual systems are subject of CERT Measure Plans like their physical counterparts. Therefore, apply the Unix/Linux Measure Plan [10] to all Unix/Linux virtual machines and the Windows Measure Plan [8][9] to all virtual machines running Microsoft Windows, respectively.

Configuration and inventory data of a vSphere installation is maintained within a SQL database. Depending on the database engine, apply the Measure Plan for Oracle RDBMS [13] or Microsoft SQL server [11].

An ESXi installation contains physical and virtual network infrastructure like physical and virtual switches and routers. Apply the *Security Measure Plan for Network Devices* [12] to physical and virtual network infrastructure.

Revision history:

- 1.0: Measure created.

3.5 Principle of Least Privilege

EVAL

mandatory

Measure M135404, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Users of a vSphere infrastructure should have only as much rights as absolutely necessary. Administrative users should be allowed to perform their administrative task, but not given the unlimited rights of the root user.

Default roles have to be avoided, as they are hard-coded within vSphere.

Measure

Apply the concept of least privileges to all users and administrators. By default, only work with higher than standard user privileges for the duration of operations that require administrative privileges.

Implementation

Define roles for users and administrative profiles in your environment. Avoid direct use of the default roles already defined in vSphere.

Make sure to know the vSphere 6 privilege description. Chapter 10 of the official VMware vSphere 6 security guide lists all available privileges. It can be obtained from <https://pubs.vmware.com/vsphere-60/topic/com.vmware.ICbase/PDF/vsphere-esxi-vcenter-server-60-security-guide.pdf>.

Add only needed privileges to the role definitions.

Revision history:

- 1.0: Measure created.

3.6 Avoid Granting Privileges to Single Users

EVAL

mandatory

Measure M135451, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

In vSphere user privileges do extend group privileges. Therefore, if a user is granted additional privileges on a per-user base, revoking group privileges may not limit the user's privileges as desired. Granting privileges to groups instead of single users eliminates the need to manage per-user privileges.

Measure

Always assign privileges to groups instead of single users, if there are no strong reasons against it.

Exception

User privileges may only be granted to system users like *vpuser* or to allow emergency access to a single administrative user per installation.

Implementation

N/A

Revision history:

- 1.0: Measure created.

3.7 Use Siemens PKI Certificates

EVAL

mandatory

Measure M135278, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

vSphere supports encryption of traffic and the use of SSL certificates. By default, vCenter Server and ESXi use self-generated certificates that are created as part of the installation process. Such certificates are not verifiable and are not signed by a trusted, well-known certificate authority. These default certificates are vulnerable to man-in-the-middle attacks.

Measure

The default SSL certificates of all vSphere components must be replaced with certificates from the Siemens PKI as defined in the *Topic-Specific ISEC Policy: Cryptography*, [5].

Ensure that the private key of the host certificate is only readable by *root* and not writable at all.

Exception

For services not reachable from the Siemens Intranet or the Internet, self-signed certificates may be used. Ensure that every user of suchlike services imports the fingerprint of the certificate into the client software like vSphere Client or Internet Explorer.

Implementation

Siemens PKI certificates can be obtained from the Siemens Server Registration Authority (Server RA – <https://server-certificates.siemens.net/>). Alternatively, machine certificates may be used on systems registered in Siemens' Active Directory.

To change certificates of ESXi hosts, log in to the ESXi shell as a user with administrator privileges. In the directory `/etc/vmware/ssl`, rename any existing certificates and install the Siemens certificates. However, **do not use** the tool `/sbin/generate-certificates` to generate new certificates. Use certificates from the Siemens PKI instead.

An HTTP PUT request can be used to deploy the new certificates to the ESXi hosts. Make sure to use HTTPS when deploying new certificates onto any ESXi host. The following locations can be used for deployment:

Certificates `https://hostname/host/ssl_crt`
Keys `https://hostname/host/ssl_key`

To protect the private key of the host certificate, ensure that the file `/etc/vmware/ssl/rui.key` has its access rights set to `0400` and its user and group ownership are both set to *root*.

To change SSL certificates for other vSphere components follow the corresponding VMware documentation:

- [VMware Knowledge Base article 2097936: How to use vSphere 6.x Certificate Manager](#)

- [VMware Knowledge Base article 2111219: Replacing default certificates with CA signed SSL certificates in vSphere 6.x](#)
- [VMware vSphere 6.0 Documentation Center: Where vSphere 6.0 Uses Certificates](#)

Automated API-based certificate modifications can be secured by using VLAN separation, proper access control lists on local firewalls, network based firewalls, or routers are considered sufficient for preventing access from the Siemens Intranet to vSphere components.

Revision history:

- 1.0: Measure created.

3.8 Protecting Physical Interfaces

EVAL

mandatory

Measure M135125, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Open communication interfaces (COM, LPT, USB, IR, SCSI, etc.) can be used to exchange data which cannot be controlled with standard authentication and access mechanisms. To limit the attack surface of hardware components of a vSphere infrastructure, all unused communication interfaces must be properly secured.

Measure

Disable all unneeded physical communication interfaces upon all hardware components of which the vSphere infrastructure is composed of.

Alternatively, physically secure the hardware components of the vSphere infrastructure.

Implementation

Some interfaces might be disabled by using the corresponding BIOS settings.

For all remaining unused interfaces apply one of the following actions:

- Deactivate the physical connections of the communication interfaces,
- Prevent the loading of the corresponding interface drivers,
- Protect the interfaces in the operating system by assigning appropriate authorizations to the device files.

The last action is also to be carried out for communication interfaces which are in use, including logical interfaces.

Alternatively, restrict physical access to the hardware to authorized personnel.

Revision history:

- 1.0: measures created

3.9 Secure Built-in Remote Management Interface

EVAL

mandatory

Measure M135269, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Modern server systems are often equipped with a built-in remote management interface. This interface can typically be used to access and manage (restart, boot from external media, etc.) the system without the need for the main operating system to be running. While this can be very useful for maintenance, these interfaces can allow an attacker to easily take over the system. Therefore, such interfaces have to be sufficiently secured.

The different server system vendors use many different names for these interfaces, including Fujitsu Integrated Remote Management Controller (iRMC), Integrated Dell Remote Access Controller (iDRAC), HP Integrated Lights Out (iLO) or IBM Integrated Management Module. More generic names for the same kind of system are Server Management Board (SMB), or Intelligent Platform Management Interface (IPMI).

Typically, these interfaces are implemented as embedded systems with an own operating system, web server, user administration and alarm management. They are operational even when the server system itself is in standby mode. Communication is carried out via LAN connection, which can be shared with the server system or used exclusively for system management.

Such built-in remote management interfaces typically come with default passwords for the main administrative user account. There is a high risk that an attacker who has access to the Siemens Intranet, can easily gain full control over a server if default security configuration has not been adjusted.

Measure

Appropriately secure built-in remote management interfaces by applying the following actions:

- Connect remote management interfaces only to a separate, isolated management network. Make sure this interface is not directly reachable from the Siemens Intranet.
- For all accounts that grant administrative access to a system the Siemens password policy for Administrators must be followed (see *Topic-Specific ISEC Policy: Access Control*, [3]).
- Always replace well-known or default passwords.
- Logging must be enabled and monitored to allow for a detailed auditing of all administrative changes to a server system via the built-in remote management interface. Alternatively, access to the network used for connecting remote management interfaces can be logged.
- Always apply the manufacturer's up-to-date security patches for the firmware of remote management interfaces.

- Limit the attack surface of the built-in remote management interface by allowing only secured protocols for access. Protocols that use plain-text transmission of passwords like telnet, SNMP and HTTP forms must be disabled.

Exception

The measure is not applicable for built-in remote management interfaces which are either deactivated or not connected to any network.

Implementation

Please consult the vendor manual of the affected hardware platforms for implementation details.

Revision history:

- 1.0: Measure created.

3.10 Configure NTP Clients

EVAL

mandatory

Measure M135319, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

A properly synchronized clock is required for a proper checking of certificates as well as synchronization of system logs. Thus, a sufficiently accurate and synchronized clock is needed upon all system that are part of a vSphere infrastructure. Typically, a vSphere installation is composed of several ESXi hosts, at least one vCenter Server and linked database system as well as third-party devices like firewalls and vSphere add-on components.

Measure

Synchronize the clock of every component with a Network Time Server via NTP.

Allow the necessary NTP traffic in the firewall configuration.

Make sure the NTP synchronization of all components is performed in regular intervals.

Implementation

Information about the Siemens NTP infrastructure is provided by Siemens CERT at <https://www.cert.siemens.com/faq/network/NTP>. For enhanced security, a local time server with DFC77 or GPS clock can be used to avoid opening firewalls for NTP traffic.

NTP usage on ESXi hosts

By default, the NTP daemon is stopped on ESXi hosts and needs to be enabled manually. From the vSphere Client connect to the vCenter Server. In installations without vCenter Server, connect to the ESXi hosts instead. For every ESXi host execute the following steps:

1. Select *Manage* → *Settings* → *Time Configuration* → *Edit*,
2. Select *Use Network Time Protocol (Enable NTP Client)*,
3. Set the NTP service status and NTP service startup policy,
4. Enter the IP addresses of the NTP servers to synchronize with.

Alternatively, the Remote Command Line Interface of ESXi can be used. In this case, the firewall setting of the ESXi host must be manually adjusted to allow NTP traffic. You can use the following command to add an NTP server:

```
vicfg-ntp.pl --add <NTP-Server>
```

Revision history:

- 1.0: Measure created.

3.11 Enable Persistent Logging

EVAL

mandatory

Measure M135612, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Logging information is fundamental for the detection and handling of security incidents. Thus, persistent logging upon all components is crucial for analyzing the state and security of any vSphere installation.

Measure

On every log-enabled component within a vSphere installation, enable at least the logging of events rated as *Warning* and *Error*. Make sure also unsuccessful login events are logged upon all components that support such a logging feature.

Store these logs for at least 90 days.

Implementation

Siemens CERT recommends to store all logs on a dedicated datastore with restricted network and physical access.

Applying logging policy to vServer host

The vSphere Client may be used to check and configure the log settings on vServer hosts:

1. Log in to vCenter Server with vSphere Client,
2. Select *Administration* → *vCenter Server Settings* → *Logging Options*,
3. Set the logging options to *Warning* or a more verbose setting. Do not choose the settings *None* or *Error*.

Applying logging policy to ESXi host

The syslog daemon is stopped by default on ESXi hosts. Thus, no permanent logging takes place and after 24 hours any logged event is gone. You can use *vCLI* or, as the following example does, the vSphere Client for configuration:

1. Log in to vCenter Server with vSphere Client and select an ESXi host,
2. Select *Manage* → *Advanced System Settings* and locate the *Syslog* entry and click *Edit*,
3. Adjust the following parameters according to your needs. Make sure that they are big enough to at least store logs for 90 days:
 - *Syslog.global.defaultRotate* sets the maximum number of archives to keep,
 - *Syslog.global.defaultSize* sets the default size in KB of the log before syslog rotates it,
 - *Syslog.global.logDir* sets the folder where logs are stored. Make sure it points to a filesystem upon a persistent media,

- *Syslog.global.logHost* points to the remote host to which logs are forwarded. An example value might be *ssl://loggingHost:1234*,

4. Click OK to apply the new policy. The effects are triggered immediately.

Alternatively, PowerCLI can be used to set those parameters upon all ESXi hosts:

```
Get-VMHost |  
Foreach {  
    Set-AdvancedSetting  
        -VMHost $_  
        -Name "Syslog.global.defaultRotate"  
        -Value "<amount>"  
}  
  
Get-VMHost |  
Foreach {  
    Set-AdvancedSetting  
        -VMHost $_  
        -Name "Syslog.global.defaultSize"  
        -Value "<size>"  
}  
  
Get-VMHost |  
Foreach {  
    Set-AdvancedSetting  
        -VMHost $_  
        -Name "Syslog.global.logDir"  
        -Value "<path>"  
}  
  
Get-VMHost |  
Foreach {  
    Set-AdvancedSetting  
        -VMHost $_  
        -Name "Syslog.global.logHost"  
        -Value "<host>"  
}
```

Other components

Consult the corresponding vendor manual for information.

Revision history:

- 1.0: Measure created.

3.12 Prevent Resource Takeover

EVAL

mandatory

Measure M135274, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

By default, virtual machines equally share all resources of an ESXi host. Thus, single guests executing resource-intensive operations are able to block a large amount of the host's resources. Such behavior may lead to a denial of service of critical virtual machines hosted on the very same ESXi instance. Using resource limitations such as shares and reservations are able to circumvent such a fatal situation.

Measure

Use limits, shares or reservations to prevent a takeover of resources from critical virtual machines by other guests.

Implementation

1. Use limits, reservations or shares to guarantee resources to critical virtual machines running on your vSphere environment,
2. Apply resource limits to virtual machines that have the potential to run resource-intensive operations,
3. Apply resource limits to virtual machines that are in high risk of being exploited or attacked. Doing so prevents even hijacked guests to request a high amount of resources.

The current resource configuration can be checked via PowerCLI:

```
Get-VM | Get-VMResourceConfiguration
```

Revision history:

- 0.9: Measure created.
- 1.0: Specified *Measure* and *Implementation* section.

4 General Network Security

4.1 Separate Management and User Networks

EVAL

mandatory

Measure M135833, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

VMware vSphere infrastructures use network connectivity for different types of traffic:

1. Traffic for the management of the vSphere installation, like

- Maintenance of the ESXi hosts,
- Connections between ESXi hosts,
- Connections to the vSphere Client,
- Connections to the vCenter Server.

This network is typically called *management network*.

2. Networks the virtual machines are connected to. Such networks are called *front-end networks*,

3. Networks for connecting storage systems to the ESXi instances. Naturally, such a type of network is known as *storage network*.

A separation of these networks limits the impact of a compromised virtual machine. Depending on the architecture of a vSphere infrastructure, sensitive data of virtual machines might pass through the management network completely unencrypted. This happens, for example, whenever virtual machines are transferred between hosts. To avoid data leakage, traffic on the management network must not be accessible from other networks.

Measure

Establish the following types of network isolation:

- The management network and the frontend network must be separated. Traffic from the frontend network must not reach the management network and vice versa,
- The storage network and the frontend network must be separated. Traffic from the frontend network must not reach the storage network and vice versa,
- The management network and the storage network should be separated. Traffic from the management network must not reach the storage network and vice versa.

Naturally, a network isolation is only fully implemented, when neither switching nor routing between separated networks takes place.

For single ESXi hosts which

- Are not managed by a vCenter Server installation,
- Do not use external storage,
- Are not used for production, like installations for tests and product evaluation,
- Have a defined date for their decommission,

the firewall of the ESXi host may be used to allow access to the management interfaces of ESXi only from defined source addresses. This alternative may only be implemented, if network separation is not technically feasible.

Implementation

Use different physical networks for storage network, frontend network, and management network. Use different physical interfaces on the ESXi server machines to connect the ESXi to those networks.

If separate physical networks are not feasible, then VLAN separation may be used instead. However, it has to be ensured that all network components involved do not allow crossing of VLANs. Furthermore, virtual machines must not be able to send or receive network packages with VLAN tags.

Revision history:

- 1.0: Measure created.

4.2 Secure vMotion Network Traffic

EVAL

mandatory

Measure M135546, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

vMotion allows a live migration of running virtual machines from one ESXi host to another ESXi host within the same vSphere infrastructure. During the migration, the current state of the virtual machine is transferred over the network. Since performance is an issue when it comes to such live migrations, the whole transfer happens completely unencrypted. Whenever such a migration takes place, the whole memory content and even CPU-internal registers as well as network states are transmitted. Therefore, every transfer contains sensitive information like plaintext passwords, caches of file-system nodes and even plaintext keys used for encryption.

To prevent accidental disclosure of such sensitive data, vMotion network traffic must be secured.

Measure

If vMotion is available in a vSphere installation, restrict vMotion traffic to a physical network exclusively used for vMotion. Note that VMware itself does recommend such a vMotion-only network for performance reasons.

Only if no dedicated vMotion network is technically feasible, the management network or storage network might be used for vMotion traffic.

Use firewall rules to ensure that no incoming connection to the vMotion socket can be made, except between the vMotion-enabled ESXi hosts of the vSphere infrastructure.

Limit the access to the vMotion network to authorized personnel.

Implementation

Per default, the vMotion service is using TCP port 8000. The firewall configuration must restrict connections to that port to the ESXi hosts of the cluster. Therefore, modify the ESXi host firewall rule labeled "vMotion" to allow connects to port 8000 only from other ESXi hosts of the infrastructure and from the vCenter Server.

Revision history:

- 1.0: Measure created.

4.3 Check Network Isolation at Regular Intervals

EVAL

mandatory

Measure M135449, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Network isolation may be circumvented by changes in the network infrastructure, fire-wall updates or compromised infrastructure components. To ensure that such a security breach does not go unnoticed, the network isolation must be checked at regular intervals. CERT recommends to perform such checks in an automated manner.

Measure

Check the network isolation by:

- Using a network scanner to verify the isolation of the management network, the Siemens Intranet and the storage network as required by Measure 4.1 (M135833),
- Using a network scanner to check only used services of a vCenter Server instance are reachable from the management network as required by Measure 5.3 (M135443).

To check that there is no routing of IP-based traffic from the Siemens Intranet to the management network and storage network, can be considered as alternative to ensure that network isolation is still in place.

Apply these checks in intervals no longer than 90 days.

Implementation

Use a network scanner like nmap on a system connected to the Siemens Intranet and scan all ports on all machines of the management network and storage network.

Use a network scanner within the management network and scan all ports of all vCenter Server instances.

Whenever unneeded services or ports are discovered, make sure to disable the corresponding services.

Revision history:

- 1.0: Measure created.

4.4 Disable Native VLAN Feature for All Switches

EVAL

mandatory

Measure M135550, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

vSphere ESXi hosts support VLAN tags to create separated networks which can span over multiple ESXi instances. In this configuration, ESXi hosts must receive VLAN tags from the connected switches to distinguish between the networks. Usually, this is achieved by connecting them to trunk ports.

Some switches support "native VLANs" meaning that all packets without VLAN tags are being assigned to a specific VLAN. Consequently, packets belonging to the native VLAN are sent to the trunk ports without VLAN tag.

This may lead to information disclosure, because packets tagged by the ESXi host with the identifier of the native VLAN may appear as untagged packets on a different ESXi host. Those packets are then incorrectly treated as packets with a VLAN identifier of 0, which means they are untagged.

Measure

Disable the native VLAN support on all switches used to interconnect the components of a vSphere infrastructure. Naturally, this only applies to switches and switch ports accepting VLAN tags.

Implementation

Consult the manual of the switches to

1. Check whether or not the switch supports native VLANs,
2. Check how native VLAN support can be disabled.

Disable native VLAN support according to the manual of the switch.

Revision history:

- 1.0: Measure created.

4.5 Disable Simple Network Management Protocol

EVAL

mandatory

Measure M135358, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The Simple Network Management Protocol (SNMP) is a standard protocol to monitor the configuration and health of a system. It also offers the feature to change configuration settings.

The SNMP versions supported by vSphere 6 do not support encryption. Therefore, credentials are transmitted in plain text. Note that credentials are called "community strings" in vSphere documentation.

Measure

Disable SNMPv1 and SNMPv2 upon all components of a vSphere infrastructure.

Exception

In case SNMP monitoring is used to monitor certain components, restrict it to networks with strong physical access control.

Implementation

ESXi hosts

Disable the SNMP service on every ESXi host using the command:

```
esxcli system snmp set --enable false
```

Other components

Check the vendor manuals on how to disable SNMP on other devices.

With enabled SNMP monitoring

Alternatively, SNMP may be allowed on a restricted network where only authorized personnel has access to. Typically, this would be the management network as described in Measure 4.1 (M135833).

Revision history:

- 1.0: Measure created.

4.6 Reject Forged Transmissions from Virtual Machines

EVAL

mandatory

Measure M135445, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The setting *Forged Transmissions* in the configuration of virtual switches affects traffic that is sent from virtual machines. When this option is set to *Accept*, an ESXi host does not compare the source MAC address from packets coming from a virtual machine with the effective MAC address from the virtual network adapter. Thus, an attacker might be able to send packages seemingly coming from a foreign source. Typically, such actions are used to perform man-in-the-middle attacks.

Measure

Set the option *Forged Transmits* to *Reject* for all virtual switches and port groups.

Exception

Only when it comes to certain failover scenarios, forged transmits may be allowed. If virtual machines require such forged transmits to be enabled, always use a separate port group on the virtual switch. Limit forged transmits to selected virtual machines, dedicated port groups and certain network adapters that actually require this feature.

Implementation

When creating a new virtual switch or port group in vSphere, check the properties of the switch and port group for the parameter *Forged Transmits*. Alternatively, it is possible to set the corresponding setting directly via ESXi shell:

```
esxcli network vswitch standard policy security set -v vSwitch2 -f false
```

Single port groups of a virtual switch may define exceptions. Therefore, the port groups of the virtual switch have to be checked, too.

Revision history:

- 1.0: Measure created.

4.7	Disable Promiscuous Mode for Virtual Network Interfaces	EVAL
		mandatory

Measure M135894, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

If a network interface is in *Promiscuous Mode*, all network traffic of the corresponding virtual switch is forwarded to that network interface. An attacker may use this functionality to receive network traffic destined for other systems and thereby gain access to sensitive information.

Measure

Disable *Promiscuous Mode* operation for all virtual switches and port groups.

Implementation

The *Promiscuous Mode* operation is disabled by default. However, when creating or changing a virtual switch or port group, check the properties of the switch and port group for the parameter *Promiscuous Mode*. This parameter must be set to *Reject*.

Alternatively, it is possible to set the corresponding setting directly via ESXi shell:

```
esxcli network vswitch standard policy security set -v vSwitch2 -p false
```

Revision history:

- 1.0: Measure created.

5 vCenter Security

5.1 Enable Network File Copy Encryption

EVAL

mandatory

Measure M135363, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Moving stopped virtual machines from one datastore to another is called *cold data migration*. In contrast to live migrations through vMotion, such migrations take place by using the network file copy protocol (NFC). Naturally, such copy processes include the virtual disk of migrated virtual machines.

By default, such cold data migrations are not encrypted. By encrypting them, the integrity and confidentiality of the migrated machines can be ensured. Otherwise, an attacker with access to the management network might gain the content of any virtual disk as soon as it is transferred via NFC.

Measure

Make sure all NFC-based migrations are encrypted.

Implementation

1. Connect to the vCenter Server,
2. Select *Settings* → *Advanced Settings* → *Edit*,
3. Enter a key called *nfc.useSSL* with a value of *true*,
4. Click *OK* to apply the change.

Revision history:

- 1.0: Measure created.

5.2 Use Active Directory Service for Authentication

EVAL

mandatory

Measure M135207, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

To prevent security risks associated with managing user accounts in multiple places, use a directory service for authentication. Siemens already provides Active Directory Services that can be used with ESXi and vCenter Server.

Measure

Use the Siemens Active Directory (AD) for authentication, if there are no strong reasons against it.

Implementation

In case the vSphere infrastructure is managed by a vCenter Server, it is sufficient to configure vCenter Server or the vCenter Authentication Proxy to use Active Directory. ESXi instances managed by such a vCenter Server do not need to be joined to the AD domain.

If the system hosting the vCenter Server is joined to a Windows domain, then vCenter Server automatically uses domain accounts for authentication.

To use directory based authentication for ESXi hosts, either use the vSphere Authentication Proxy or join the ESXi host to the domain:

1. In the vSphere Client inventory, select the host,
2. Select the *Configuration* tab and click *Authentication Services*,
3. Click *Properties*,
4. In the Directory Services Configuration dialog box, select the *Active Directory* from the drop-down menu,
5. Enter a domain,
6. Click *Join Domain*,
7. Enter the user name and password of a directory service user who has permissions to join the host to the domain and click OK.

Revision history:

- 1.0: Measure created.

5.3 Limit vCenter Server Network Connectivity

EVAL

mandatory

Measure M135443, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The vCenter Server is a critical part of any vSphere installation. To limit attack vectors to a vSphere infrastructure, the exposure of all vCenter instances to the network should be limited to the level required for operation.

Measure

Limit unneeded vCenter Server network connectivity by applying the following actions:

- Use a local firewall on the system where vCenter Server is running,
- Create IP-based access restrictions so that only necessary components can communicate with the vCenter Server system,
- Block access to ports that are not being used by vCenter Server at the firewall.

A network firewall can be used in addition or as alternative to the local firewall to limit access to the vCenter Server to necessary components and ports.

Implementation

Create and maintain a list of required connectivity for each vCenter Server installation. Limit network connectivity on the local firewall or on a network firewall according to this list. For its operation, the vCenter Server needs connectivity to the following systems:

- All ESXi hosts,
- The vCenter Server database,
- Other vCenter Server systems (when used in linked-mode),
- Systems that are authorized to run management clients. Those are, for example:
 - The vSphere Client,
 - Systems using the PowerCLI,
 - SDK-based clients,
- Systems running add-on components like VMware vSphere Update Manager,
- Infrastructure services such as DNS, Active Directory and NTP,
- Other systems that run components that are essential to the functionality of the vCenter Server System.

Revision history:

- 1.0: Measure created.

5.4 Install a Dedicated vCenter Account

EVAL

mandatory

Measure M135343, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

In prior versions of vSphere, vCenter granted administrative rights to the local Windows administrator accounts by default. A Microsoft Windows built-in account has more rights and permissions than the vCenter Server needs. In order to follow the least privilege principle, do not use the built-in Microsoft Windows accounts for vCenter.

Measure

Install a dedicated service account for vCenter.

Make sure no local administrative accounts and domain admins feature vSphere administrator privileges.

Implementation

N/A

Revision history:

- 1.0: Measure created.

5.5	Remove vSphere Administrator Privileges from Domain Admins	EVAL
		mandatory

Measure M135427, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

By default, domain administrators are granted administrator privileges on the vCenter Server. In order to achieve a separation of duties, administrative rights should be limited to a special-purpose local vSphere administrator account.

Measure

Create a special-purpose vSphere administrator account that does not belong to any group such as Administrator.

Remove the permissions in vCenter from the local administrator group and for domain administrators.

Implementation

N/A

Revision history:

- 1.0: Measure created.

5.6	Do Not Grant vSphere Access for Users of Virtual Machines	EVAL
		mandatory

Measure M135356, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Owners of virtual machines can access their machines via remote management protocols like Remote Desktop Protocol (RDP) or SSH. An owner of a virtual machine is defined as person having administrator privileges upon the guest operation system.

Therefore, these users do not require any access rights to ESXi or the vCenter Server. To follow the principle of least privilege, as defined in Measure 3.5 (M135404), it should be avoided to give these users access to the management network, as defined in Measure 4.1 (M135833). Furthermore, these users should not have any access to other components, like vCenter or ESXi hosts, of a vSphere infrastructure.

Measure

Restrict access of owners to virtual machines owned by them.

Only if there are strong reasons, you may grant access to selected owners to the

- vCenter Server,
- Management network.

Exception

This measure is not applicable, if the VM operating system administrator (provider) is different from VM owner (customer). For example, data center operators may have vCenter access for providing *managed servers* to customers.

Implementation

Whenever creating virtual machines, do **not**

- Generate a vCenter account by default,
- Assign vCenter access rights to the administrator of the virtual machine.

Instead of giving console access, hand out the initial administrator credentials, like an initial root password, to the owner of a new virtual machine. The owner of the virtual machine can use this account to access the system over the user network as defined in Measure 4.1 (M135833). Remember that such initial credentials must be changed as soon as possible according to *Topic-Specific ISEC Policy: Access Control*, [3].

Revision history:

- 1.0: Measure created.

5.7 Secure vCenter Single Sign On

EVAL

mandatory

Measure M135444, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

vSphere 6 features an optional *vCenter Single Sign On* (SSO) component. It can take advantage of several identity sources to authenticate users of the vSphere installation. Furthermore, it can be used to define requirements to passwords and thereby increase security.

Measure

If vCenter Single Sign On is in use

- Limit the set of identity sources to the required minimum,
- Limit the set of default domains to the required minimum,
- Set the *Lockout Policy* to lock accounts after 3 failed login attempts within 5 minutes. Such accounts must be locked for a minimum of 10 minutes.

Stricter values may be defined as well.

Implementation

Log in to the vSphere Web Client using an account with vCenter Single Sign On administrator privileges. This account is different from the vSphere Administrator account and often called *admin@system-domain*.

To check the list of default domains:

1. Select *Administration* → *Sign-On and Discovery* → *Configuration*,
2. In the *Identity Sources* tab, check the list of default domains,
3. If a domain is no longer in use, select it and click *Remove*.

To check the list of identity sources:

1. Select *Administration* → *Sign-On and Discovery* → *Configuration*,
2. In the *Identity Sources* tab, check the list of identity sources and remove unneeded ones.

To set the lockout policy:

1. Select *Administration* → *Sign-On and Discovery* → *Configuration*,
2. Select *Lockout Policy* in the *Policy* tab,

3. Edit the *Lockout Policy Basics* and *Configuration* parameters:

Max number of failed login attempts	3
Time interval between failures	300
Unlock time	600

Explicit unlocking of an account by an administrator is needed when *Unlock time* is set to a value of 0.

Note that the policies defined in vCenter SSO are not applied to local OS users or accounts defined in LDAP or Active Directory.

Revision history:

- 1.0: Measure created.

6 ESXi Security

6.1 Enable lockdown mode

EVAL

mandatory

Measure M135165, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

In *normal mode*, users with permissions on ESXi hosts can bypass vCenter usage and directly change the configuration of ESXi hosts. Thereby, users may bypass logging facilities of the vCenter Server. If local users or local firewalls rules are changed on the ESXi host, then those changes will not appear in the vCenter Server. Furthermore, all users with the DCUI (direct console UI) access privilege are granted the administrator role on the host in *normal mode*.

Lockdown mode limits access to the ESXi host to vSphere and users with the DCUI access privilege.

Measure

For all ESXi hosts which are managed by vCenter enable *lockdown mode*.

Exception

This measure does not apply to ESXi hosts that are not registered to a vCenter Server. Do not enable *lockdown mode* on standalone ESXi instances.

Implementation

In the vSphere Client, select the *ESXi host* → *Configuration* → *Security Profile* → *Edit link* next to *lockdown mode*. Select *Enable Lockdown Mode*. Alternatively, *Lockdown mode* can also be activated via vSphere Web Client or from the Direct Console UI (DCUI).

Siemens CERT highly recommends to ensure that DCUI is enabled. In case of lost access to the vCenter Server, DCUI can be used as emergency access to ESXi hosts.

Revision history:

- 1.0: Measure created.

6.2 Enable ESXi Firewall

EVAL

mandatory

Measure M135863, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

ESXi hosts feature a built-in firewall. This firewall adapts to configuration changes and provides a basic protection layer. In order to decrease the potential attack surface - even within a dedicated management network - only allow communication streams of active services to pass the firewall.

Measure

- a) Enable the built-in firewall on all ESXi hosts,
- b) Check all enabled services upon every host and apply firewall rules according to the following scheme:
 - A service accessed by clients outside the vSphere infrastructure may be set to *All*,
 - Services, whose access is limited to clients within the vSphere infrastructure, must be only accessible from vSphere-internal addresses.
- c) Make sure to check the firewall configuration in intervals no longer than 90 days.

Implementation

The firewall on an ESXi host is enabled by default. However, the setting can be checked with vSphere-Client or on the ESXi-Shell with the following command:

```
esxcli network firewall get
```

The list of allowed IP ranges can be checked on the ESXi-Shell as well. Use the following command to do so:

```
esxcli network firewall ruleset allowedip list
```

Revision history:

- 0.9: Measure created.
- 1.0: Specified *Measure* and *Explanation* section for better understanding.

6.3 Control CIM-based Hardware Monitoring Tool Access

EVAL

mandatory

Measure M135413, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The *Common Information Model* (CIM) system provides an interface for managing hardware from remote applications using a set of standard APIs. VMware also develops CIM providers for monitoring and management of particular devices like monitoring of server hardware, ESXi storage infrastructure, and virtualization specific resources.

Services accounts used by management applications should be restricted to the minimum set of required privileges as required by Measure 3.5 (M135404). By doing so, the effect of information disclosure is limited in case a service account is compromised.

Measure

Disable the CIM service on any ESXi host.

Exception

If there are strong reasons to use CIM access, make sure to avoid using standard accounts. Create a separate service account specific to CIM applications instead.

Implementation

In order to deactivate the CIM agent on an ESXi host, execute the following actions:

1. Log in to the ESX host via SSH,
2. Run these commands:

```
service sfcdb stop  
chkconfig sfcdb-watchdog off  
chkconfig sfcdb off
```

If CIM access is needed, apply these steps:

1. Create a service account specific to CIM applications,
2. Grant read-only access to CIM information to any local account defined on the ESXi system, as well as any role defined in vCenter Server,
3. If the application requires write access to the CIM interface, create a role to apply to the service account with only two privileges:
 - *Host.Config.SystemManagement*,
 - *Host.CIM.CIMInteraction*.

Revision history:

- 1.0: Measure created.

6.4 Do Not Use the Root User

EVAL

mandatory

Measure M135895, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

A single, centralized administrator account is critical when it comes to log analyses in case of maintenance, debug and security issues. If all administrators log in as the root user, it is impossible to tell which administrator performed which action. When different users feature administrative permissions, the actions of those accounts can be tracked.

Measure

On every ESXi host within a vSphere infrastructure

- Assign the administrator role to a user account different from *root* or *Administrator*,
- Change permissions, so that the *root* user has no longer administrator privileges.

This measure only affects the vSphere privileges of the *root* user on an ESXi host. The system privileges on operating system level are explicitly not within the scope of this measure. Do not remove this user under any circumstances!

Exception

This measure does not apply to the account *vpxuser* as it is used by the vCenter Server to access ESXi hosts. Therefore, its settings and its password must not be changed.

The *dcui* user may remain enabled for emergency access to the hypervisor. By doing so, it enables administrative access to ESXi servers if lockdown mode is enabled and the vCenter Server system is not responding (see **M135165**).

Implementation

To remove the administrator privileges from the local *root* user, follow these steps:

1. Use the vSphere Client to log in to every ESXi host. Note that local users on ESXi hosts cannot be modified via vCenter Server,
2. Select the ESXi host and open the *Local Users & Groups* tab,
3. If not existent, add a new user for emergency access,
4. Open the *Permissions* tab and assign the Administrator role to the new user,
5. Reconnect with the new user to the ESXi host,
6. Remove the Administrator role from the user named *root*.

Revision history:

- 1.0: Measure created.

6.5 Disable ESXi Privileges for AD Group "ESX Admins"

EVAL

mandatory

Measure M135751, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

If VMware vSphere is joined to the Active Directory system, then by default every member of the AD group *ESX Admins* gets administrative privileges on every ESXi host.

Such a behavior may lead to inadvertent granting of privileges on a large number of ESXi hosts. Consequently, this automatism should be disabled and the default *esxAdmins-Group* parameter must be changed to reflect the desired target systems.

Measure

Disable full admin access for the AD *ESX Admins* group upon all ESXi hosts - no matter if the ESXi host is joined to the Active Directory or not.

If single ESXi hosts are joined to the AD, then additionally change the *esxAdminsGroup* parameter on those ESXi hosts to a non-default value. This value should reflect the intended group of systems and authorized personnel.

Implementation

On every affected ESXi host:

- Change the value of *Config.HostAgent.plugins.hostsvc.esxAdminsGroup* to a value other than "ESX Admins",
- Set the value of *Config.HostAgent.plugins.hostsvc.esxAdminsGroupAutoAdd* to "false".

The following PowerCLI command can be used for fast verification of the above-mentioned parameter values:

```
Get-VMHost |
  Select Name,
    @{N="esxAdminsGroup";
      E={
        $_ |
        Get-VMHostAdvancedConfiguration `
          Config.HostAgent.plugins.hostsvc.esxAdminsGroup |
        Select -ExpandProperty Values}},
    @{N="esxAdminsGroupAutoAdd";
      E={$_ |
        Get-VMHostAdvancedConfiguration `
          Config.HostAgent.plugins.hostsvc.esxAdminsGroupAutoAdd |
        Select -ExpandProperty Values}}
```

Revision history:

- 1.0: Measure created.

6.6 Only Use Drivers from Trusted Sources

EVAL

mandatory

Measure M135584, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Kernel modules for ESXi are available from different sources. These modules have full access to the hypervisor and all virtual machines. Such an access also includes the ability of read any temporarily stored information like non-encrypted keys and passwords within the virtual memory of all virtual machines on the corresponding host. Therefore, such modules need to be installed from trusted sources.

Measure

Only use VMkernel modules from trusted sources by setting the *Host Image Profile Acceptance Level* to *VMwareCertified* or *VMwareAccepted*.

Validate their signatures whenever possible.

Exception

Some hardware vendors require to set the *Host Image Profile Acceptance Level* to *Partner Supported*. For suchlike hardware, stricter settings like *VMwareCertified* or *VMwareAccepted* cannot be applied.

Implementation

When installing drivers for ESXi, check the signature of the driver/kernel-module. Only accept valid signatures from VMware and trusted vendors.

To restrict the accepted installation sources with vSphere Client, log in to vCenter or an ESXi host and

1. Select the host to configure,
2. In the tab *Configuration* select *Security profile*,
3. Set the *Host Image Profile Acceptance Level* to *VMwareCertified* or *VMwareAccepted*.

Revision history:

- 1.0: Measure created.

6.7 Secure Storage Traffic

EVAL

mandatory

Measure M135481, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

In a typical vSphere environment, ESXi hosts use external storage for hosting virtual machine data. Usually, the connection between the storage device and the ESXi host is not encrypted. Therefore, an attacker with access to the storage network may read all data that is read or written to virtual disks. Such data typically include sensitive information like configuration files, passwords stores in plain-text as well as the actual information that is stored or processed within virtual machines. To prevent accidental disclosure of this information, storage traffic must be secured.

Measure

Physically secure the storage network infrastructure.

Only if physical network separation is not feasible, VLAN separation may be used instead. When taking advantage of VLAN features, it has to be ensured that all network components involved do not allow crossing of VLANs. Furthermore, virtual machines must not be able to send or receive network packages with VLAN tags.

Implementation

Use a separate physical network for storage traffic and restrict network access to authorized personnel.

Revision history:

- 1.0: Measure created.

6.8 Secure the ESXi Shell

EVAL

mandatory

Measure M135711, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

ESXi shell allows to execute system commands on ESXi host systems. The shell can be accessed via three different services:

ESXi shell This service allows access to the shell locally.

SSH This service allows access to the ESXi shell via the network.

Direct Console UI (DCUI) When this service is enabled while the system is in lockdown mode, a user with the DCUI access privilege can log in and disable lockdown mode. Then ESXi Shell can be enabled and accessed.

Measure

The following steps have to be implemented on every ESXi host:

- ESXi shell and SSH must be disabled and may be only temporarily enabled for maintaining purposes,
- Configure a timeout for ESXi Shell availability not longer than 60 minutes,
- Configure a timeout for idle ESXi shell sessions not longer than 5 minutes.

Implementation

Procedure to enable or disable ESXi or SSH via vSphere Client

1. Log in to a vCenter Server system or the ESXi host using vSphere Client,
2. Select the host in the inventory panel,
3. Select *Security Profile* in the *Configuration* tab,
4. In the *Services* section, select *Properties*,
5. Select *ESXi Shell* or *SSH* from the list,
6. Click *Options* and select *Start and stop manually*,
7. Select *Start* to enable the service or *Stop* to disable it.

Procedure to set ESXi Shell availability timeout and ESXi Shell session timeout

1. Log in to a vCenter Server system or the ESXi host using vSphere Client,
2. Select the host in the inventory panel,
3. Select the *Configuration* tab,
4. Under *Software*, select *Advanced Settings*,

5. In the left panel, select *UserVars*,
6. Set *UserVars.ESXiShellTimeOut* to a value between 1 and 3600,
7. Set *UserVars.ESXiShellInteractiveTimeOut* to a value between 1 and 1800,
8. If the services SSH or ESXi-Shell are active, then restart the services.

Alternatively, PowerCLI can be used to trigger these changes upon all ESXi hosts:

```
Get-VMHosts | Set-AdvancedSetting
  -name "UserVars.ESXiShellTimeOut"
  -value 3600

Get-VMHosts | Set-AdvancedSetting
  -name "UserVars.ESXiShellInteractiveTimeOut"
  -value 300
```

Note that a timeout of zero is equivalent to "no timeout at all".

The parameter *UserVars.ESXiShellTimeOut* causes SSH and ESXi-Shell to terminate after not being used for the specified time-out. However, be aware that this does not re-enable lockdown mode.

Revision history:

- 1.0: Measure created.

6.9 Disable Managed Object Browser

EVAL

mandatory

Measure M135770, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

By using the *managed object browser* (MOB) users can navigate through VMkernel objects and invoke methods. Changes triggered through MOB immediately take effect on the server. However, attacks might use this interface to insert malicious settings onto ESXi hosts which might even revoke security measures. Due to this, VMware recommends to use the MOB feature only for debugging purposes and deactivate it on production environments.

Measure

Make sure the *managed object browser* is disabled upon all ESXi hosts in a vSphere infrastructure.

Implementation

1. Connect to the vCenter Server,
2. Select *Settings* → *Advanced Settings* → *Edit*,
3. Set *Config.HostAgent.plugins.solo.enableMob* to a value of *false*,
4. Click OK to apply the change.

Alternatively, use the following PowerCLI command to apply the setting upon all hosts:

```
Get-VMHost |  
Foreach {  
    Set-VMHostAdvancedConfiguration  
        -VMHost $_  
        -Name "Config.HostAgent.plugins.solo.enableMob"  
        -Value $false  
}
```

Revision history:

- 1.0: Measure created.

6.10 Centralized Collection of Core Dumps

EVAL

mandatory

Measure M135825, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Whenever a virtual machine crashes, an analysis of the resulting core dump can be performed in order to identify the reason for the crash. Centralized core dumps transmitted via network help to maintain such information in case of emergencies or security incidents. Even when an ESXi host should be compromised or a kernel panic occurs, unmodified core dump information of virtual machines are still available.

The *ESXi Dump Collector* feature is already build-in on ESXi hosts and provides the functions to implement this measure.

Measure

For ESXi servers which are hosting one or multiple systems with an ACP rating of 2 or 3 - either in Confidentiality or Integrity:

- a) Provide a host for centralized core dumping,
- b) Apply appropriate network isolation to this log collection host,
- c) Make sure all affected ESXi servers of a vSphere installation are using the *ESXi Dump Collector* feature to transport core dumps to this central destination.

Implementation

The vSphere ESXi Dump Collector service is pre-packaged with the vCenter Server Virtual Appliance. CERT recommends to use the vCenter host for this purpose.

Apply the following commands every ESXi host within your vSphere environment:

```
esxcli system coredump network set -v <VMK> -i <SERVER> -o <PORT>  
esxcli system coredump network set -e true
```

Revision history:

- 0.9: Measure created.
- 1.0: Limited the measure to specific ACP levels in order to avoid core dumps for non-critical system; removed the *Exception* section.

6.11 Prevent Unintended Usage of dvfilter API

EVAL

mandatory

Measure M135342, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Network packets to virtual machines can be inspected through a vSphere Network Appliance (dvfilter). Those filters reside in the network stream between the virtual machine and the corresponding virtual switch. They can intercept packets from and to guests. Malicious software using dvfilters might tamper with network traffic of virtual machines. Therefore, all environments not using a vSphere Network Appliance need to ensure that those features are disabled.

Measure

Disable the dvfilter API upon all ESXi hosts.

Exception

Environments where network interception products take advantage of dvfilters to protect, monitor or debug virtual machines are not required to implement this measure.

Implementation

1. Connect to the vCenter Server,
2. Select *Settings* → *Advanced Settings* → *Edit*,
3. Set *Net.DVFilterBindIpAddress* to an empty value,
4. Click *OK* to apply the change.

Disable the corresponding API setting, for example through PowerCLI:

```
Get-VMHost |  
Foreach {  
    Set-VMHostAdvancedConfiguration  
        -VMHost $_  
        -Name "Net.DVFilterBindIpAddress"  
        -Value ""  
}
```

Revision history:

- 0.9: Measure created.
- 1.0: Added more use cases for dvfilter API to the *Exception* section.

7 Virtual Machine Security

7.1 Disable Copy-and-Paste and Drag-and-Drop Operations

EVAL

mandatory

Measure M135160, created on 2017-03-31. EVAL flag expires 2017-06-30.

Explanation

Copy and paste operations between the guest operating system and remote console can transmit sensitive information between the guest OS and the remote console. Even password safe applications like KeePass use copy and paste operations to transfer stored passwords between the password safe and the application needing the password. The same problem applies for drag-and-drop operation support.

If copy and paste operations between the guest operating system and the remote console are enabled, then a manipulated guest or remote console may be able to retrieve sensible information stored in copy buffers.

Measure

Disable copy-and-paste as well as drag-and-drop operations between the guest operating system and the remote console within every virtual machine on your vSphere environment.

Implementation

To disable copy-and-paste as well as drag-and-drop using vSphere Client, follow this procedure:

1. Turn off the virtual machine,
2. Select the virtual machine in vSphere Client,
3. Select *Options* → *Advanced* → *General* and click *Configuration Parameters*,
4. Ensure that the values
 - *isolation.tools.copy.disable*,
 - *isolation.tools.paste.disable*,
 - *isolation.tools.dnd.disable*,

are set to *true* and

- *isolation.tools.setGUIOptions.enable*

is set to *false*.

If the values are missing, click "Add Row" to add them.

Alternatively, run following PowerCLI commands:

```
Get-VM | New-AdvancedSetting
    -name "isolation.tools.copy.disable"
    -value $true

Get-VM | New-AdvancedSetting
    -name "isolation.tools.paste.disable"
    -value $true

Get-VM | New-AdvancedSetting
    -name "isolation.tools.dnd.disable"
    -value $true

Get-VM | New-AdvancedSetting
    -name "isolation.tools.setGUIOptions.enable"
    -value $false
```

Revision history:

- 1.0: Measure created.

7.2 Disable Shared Console Sessions

EVAL

mandatory

Measure M135685, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

By default, more than one user can connect to a virtual machine remote console session at a time. If multiple users connect to a remote console, every connected user can observe the operations performed by other remote console users. This allows non-administrator users to connect to the virtual machine and observe the administrator's actions.

Measure

Limit the number of concurrent console sessions to a virtual machine to 1 upon all virtual machines of a vSphere infrastructure.

Exception

A higher limit may only be set

- If all users with console access to a virtual machines are informed about the possibility of concurrent console access,
- There are no specific requirements in regard to accountability of the virtual machine management for that vSphere installation (e.g. compliance regulations).

Due to a bug in the VMware vCloud Director, sessions are not terminated when orchestrating a vSphere environment. Until the bug is resolved, this measure does not apply on environments where the vCloud Director is used.

Implementation

In vSphere Client, follow these steps to adjust the shared console settings for a virtual machine:

1. Right-click the virtual machine and click *Edit Settings*,
2. Select *VM Options*,
3. Click *Advanced* and click *Edit Configuration*,
4. Add or edit the parameter *RemoteDisplay.maxConnections* and set the value to 1,
5. Click OK.

Alternatively, a PowerCLI command can be used to apply the setting:

```
Get-VM | New-AdvancedSetting -Name "RemoteDisplay.maxConnections" -value 1
```

Revision history:

- 1.0: Measure created.

7.3 Disable Unused Display Features

EVAL

mandatory

Measure M135835, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Due to performance reasons vSphere allows virtual machines to render 3D graphics directly on the host's graphic processing unit (GPU). This is done by using complex OpenGL and Direct3D APIs. Security vulnerabilities within layers handling this 3D acceleration process can lead to memory corruption, denial of service and ultimately to remote code execution attacks.

Most virtual machine do not require real hardware-based 3D acceleration. Deactivating the direct 3D support for virtual machines that do not feature graphical user interfaces (GUI) can prevent the usage of such vulnerabilities.

Measure

Disable 3D hardware-based acceleration for all virtual machines that do not use them. Disable the SVGA feature for all virtual machines that do not use them. Typically, those are Linux or Unix guests without an X Window system.

Exception

If a virtual machine requires 3D hardware-based acceleration or the SVGA feature, ensure that the latest graphic driver is installed on those virtual machines.

Implementation

Turn off the affected virtual machine and edit its settings according to the following actions:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set *mks.enable3d* to *false*,
3. For virtual machines that do not require a virtual video card, set *svga.vgaonly* to *true*.
4. Apply the adjustment by clicking on *OK*.

Alternatively, a PowerCLI command can be used to apply the setting:

```
Get-VM | New-AdvancedSetting -Name "mks.enable3d" -value $false
```

Revision history:

- 1.0: Measure created.

7.4 Disable Unity Features

EVAL

mandatory

Measure M135621, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

To enhance the user experience VMware introduced a set of features called *Unity*. It can be used on guests running a current Linux or Windows operating system. Major features of *Unity* include the copy and paste integration between host and guest, virtual machine applications that appear on the host system desktop and file system interaction between host and guest systems. In order to reduce the potential for vulnerabilities, the whole feature set has to be disabled.

Measure

Disable all Unity features for every virtual machine intended for export to client systems (e.g. VMware Workstation).

Implementation

Turn off the affected virtual machine and edit its settings according to the following actions:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set all of the following values to *true*:
 - `isolation.tools.unity.windowsContents.disable`,
 - `isolation.tools.unity.update.disable`,
 - `isolation.tools.unity.taskbar.disable`,
 - `isolation.tools.unityActive.disable`,
 - `isolation.tools.unityInterlockOperation.disable`,
 - `isolation.tools.unity.disable`.
3. Apply the adjustment by clicking on *OK*.

Alternatively, run following PowerCLI commands:

```
Get-VM | New-AdvancedSetting
  -name "isolation.tools.unity.windowsContents.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.unity.update.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.unity.taskbar.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.unityActive.disable"
  -value $true
```

```
Get-VM | New-AdvancedSetting
  -name "isolation.tools.unityInterlockOperation.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.unity.disable"
  -value $true
```

Revision history:

- 0.9: Measure created.
- 1.0: Updated *Measure* section in order to limit measure to guests intended for client-export.

7.5 Disable Unexposed VMX Features

EVAL

mandatory

Measure M135565, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Usually, VMware virtual machines are configured to support a wide range of VMware products and their features. Thus, unnecessary configuration settings are applied to virtual machines running on a vSphere installation by default. Deactivating those unused VMX features significantly limits the attack surface of virtual machines.

Measure

Disable all unused VMX features for every virtual machine intended for export to client systems (e.g. VMware Workstation).

Implementation

Turn off the affected virtual machine and edit its settings according to the following actions:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set all of the following values to *true*:
 - `isolation.bios.bbs.disable`,
 - `isolation.tools.hgfsServerSet.disable`,
 - `isolation.tools.memSchedFakeSampleStats.disable`,
 - `isolation.tools.getCreds.disable`,
 - `isolation.tools.dispTopoRequest.disable`,
 - `isolation.tools.trashFolderState.disable`,
 - `isolation.tools.guestDnDVersionSet.disable`,
 - `isolation.tools.vmxDnDVersionGet.disable`,
 - `isolation.tools.ghi.launchmenu.change`,
 - `isolation.tools.ghi.autologon.disable`,
 - `isolation.tools.ghi.trayicon.disable`,
 - `isolation.tools.ghi.host.shellAction.disable`,
 - `isolation.tools.ghi.protocolhandler.info.disable`.
3. Apply the adjustments by clicking on *OK*.

Alternatively, run following PowerCLI commands:

```
Get-VM | New-AdvancedSetting
  -name "isolation.bios.bbs.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.hgfsServerSet.disable"
  -value $true
```

```
Get-VM | New-AdvancedSetting
  -name "isolation.tools.memSchedFakeSampleStats.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.getCreds.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.dispTopoRequest.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.trashFolderState.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.guestDnDVersionSet.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.vmxDnDVersionGet.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.ghi.launchmenu.change"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.ghi.autologon.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.ghi.trayicon.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.ghi.host.shellAction.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.ghi.protocolhandler.info.disable"
  -value $true
```

Revision history:

- 0.9: Measure created.
- 1.0: Updated *Measure* section in order to limit measure to guests intended for client-export.

7.6 Disable VIX Messages from Virtual Machines

EVAL

mandatory

Measure M135674, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The *VIX programming interface* is an API of VMware to automate virtual machine operations and manipulate files within guests. However, most vSphere environments do not use custom *VIX programming*. Even if the VIX API is actually deprecated for vSphere installations since 2012, it is still available within these environments. Disabling the VIX API decreases the attack surface of vSphere installations.

Please note that VIX operations outside of virtual machines are not affected by this measure. Third party plugins should not be affected unless they use the already deprecated VIX interface to automate processes within guest operating systems.

Measure

Disable the *VIX programming interface* for all virtual machines.

Implementation

The vSphere Client may be used to check and configure this property of virtual machines:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set *isolation.tools.vixMessage.disable* to *true*,
3. Apply the adjustment by clicking on *OK*.

Alternatively, use PowerCLI to adjust this setting for all virtual machines on your vSphere installation:

```
Get-VM | New-AdvancedSetting  
-name "isolation.tools.vixMessage.disable"  
-value $true
```

Revision history:

- 1.0: Measure created.

7.7 Limit Host Information Sharing

EVAL

mandatory

Measure M135702, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

With the feature *host information sharing* virtual machines can gather information about the physical host they are executed on. Attackers might use these information to plan further attacks to the vSphere environment. Disabling this feature limits the potential information leak.

Measure

Disable *host information sharing* upon all virtual machines.

Implementation

The vSphere Client may be used to check and configure this property of virtual machines:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set *tools.guestlib.enableHostInfo* to *false*,
3. Apply the adjustment by clicking on *OK*.

Alternatively, use PowerCLI to adjust this setting for all virtual machines on your vSphere installation:

```
Get-VM | New-AdvancedSetting  
-name "tools.guestlib.enableHostInfo"  
-value $false
```

Revision history:

- 1.0: Measure created.

7.8	Reject MAC Address Changes by Virtual Machines	EVAL
		mandatory

Measure M135327, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The setting *MAC Address Changes* in the configuration of virtual switches affects traffic that a virtual machine receives.

When this option is set to *Accept*, ESXi accepts requests to change the effective MAC address to other than the initial MAC address. By allowing this, a compromised virtual machine can impersonate another system and may receive the network traffic of that system. An attacker can use this to retrieve sensitive information.

Measure

Set the option *MAC Address Changes* to *Reject* for all virtual switches.

Exception

If hot-failover scenarios or the integration of iSCSI require this feature the measure can be omitted.

Instead, use a separate port group on the virtual switch to allow MAC address changes only for the virtual machines which require it.

Implementation

When creating a new virtual switch in vSphere, check the properties of the switch for the parameter *MAC Address Changes*. This parameter must be set to *Reject*.

Single port groups of a virtual switch may define exceptions. Therefore, the port groups of the virtual switch have to be checked, too.

The integration of iSCSI may require *MAC Address Changes* to be set to *Accept*. Consult the manual of the iSCSI storage system and the iSCSI initiator to check if MAC address changes have to be allowed.

Revision history:

- 1.0: Measure created.

7.9	Limit Information Messages Stores Within VMX Files	EVAL
		mandatory

Measure M135793, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

VMX files hold configurations of virtual machines. Additionally, these files can store information messages transmitted by the virtual machine itself. Storing large chunks of data within those files can lead to full datastores. In the worst case, such a behavior can lead to a denial of Service once the datastore capacity is reached. Limiting the size of any key-value-tuple stored in the VMX files can help to reduce the attack surface of vSphere environments.

Measure

Limit the size of key-value-tuples within a VMX file to 1 MB or less.

Implementation

The vSphere Client may be used to check and configure this property of virtual machines:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set *tools.setInfo.sizeLimit* to *1048576*,
3. Apply the adjustment by clicking on *OK*.

Alternatively, use PowerCLI to adjust this setting for all virtual machines on your vSphere installation:

```
Get-VM | New-AdvancedSetting  
-name "tools.setInfo.sizeLimit"  
-value 1048576
```

Revision history:

- 1.0: Measure created.

7.10 Limit Log File Numbers and Size for Virtual Machines

EVAL

mandatory

Measure M135736, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Virtual machines can write debug information into a virtual machine log file stored on the VMFS volume. Virtual machine users and processes can abuse logging to consume large amounts of disk space on the host file system. Over time, the log file can consume enough space to cause a denial of service.

These debug log files do usually not contain useful information needed for the handling of security incidents. Thus, disabling them should be preferred when there is no need for such an extended logging of virtual machines.

Measure

Disable virtual machine debug log files.

Exception

If debug log files are required, limit the total size and number of log files for virtual machines.

Implementation

Follow this procedure to disable logging for a virtual machine:

1. Log in to the vCenter Server system or ESXi host using the vSphere Client,
2. Select the virtual machine,
3. On the *Summary* tab, select *Edit Settings...*,
4. On the *Options* tab select *Advanced* → *General*,
5. In Settings, deselect *Enable logging*.

The size limit of the log files of virtual machines should be based on the logging requirements, the number of virtual machines, and the available storage on the corresponding datastores. Follow this procedure to limit the log file numbers and size using vSphere Client:

1. Log in to the vCenter Server system or ESXi host using the vSphere Client,
2. Select the virtual machine to change,
3. On the *Summary* tab, select *Edit Settings...*,
4. On the *Options* tab select *Advanced* → *General*,
5. Select *Configuration Parameters...*,
6. Add or edit the following configuration parameters:

log.rotateSize Set this value to the maximum log file size in bytes. CERT recommends a value of 1024000,

log.keepOld Set this value to the maximum number of log files to keep. CERT recommends a value of 10.

Alternatively, you can use the following PowerCLI statement to set the recommended values:

Get-VM New-AdvancedSetting -Name "log.keepOld" -value 10
Get-VM New-AdvancedSetting -Name "log.rotateSize" -value 1024000

Revision history:

- 1.0: Measure created.

7.11 Prevent Virtual Disk Operations

EVAL

mandatory

Measure M135640, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Normal, non-administrative users of virtual machines are able to shrink virtual disks. A typical scenario where such an action might be applied is to reclaim unused space of a disk. However, repeatedly shrinking of virtual disks can lead to a corrupt disk and might cause a denial of service. Thus, deactivating this functionality can help to increase availability and integrity of virtual machines.

Measure

Deactivate functionality of virtual disk shrinking upon all virtual machines on your vSphere infrastructure.

Exception

The measure does not apply if there are strong reasons for enabled virtual disk shrinking functionality within your vSphere infrastructure.

Implementation

Turn off the affected virtual machine and edit its settings according to the following actions:

1. Select *VM Options* → *Advanced* → *Edit Configuration*,
2. Set both of the following values to *true*:
 - *isolation.tools.diskWiper.disable*,
 - *isolation.tools.diskShrink.disable*.
3. Apply the adjustment by clicking on *OK*.

Alternatively, it is possible to apply those settings via PowerCLI:

```
Get-VM | New-AdvancedSetting
  -name "isolation.tools.diskWiper.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.tools.diskShrink.disable"
  -value $true
```

Revision history:

- 1.0: Measure created.

7.12 Secure Connected Devices

EVAL

mandatory

Measure M135956, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Any enabled or connected device poses a potential attack channel. Users and processes without privileges on a virtual machine can connect or disconnect hardware devices, such as network adapters and CD-ROM drives. Attackers might use this capability to breach virtual machine security. Removing unnecessary hardware devices can help prevent attacks.

By default, virtual machines do not have direct access to host devices. If a virtual machine does need access to host devices, an attacker can cause a denial of service condition by disconnecting the device.

Measure

Disable the direct use of host hardware by virtual machines.

In cases where host devices are used by a virtual machine, prevent virtual machine users or processes from disconnecting devices.

Exception

If there are strong reasons to use host devices, the measure may be omitted.

Implementation

To verify that there are no host devices connected to the virtual machine, follow these steps:

1. Log in to the vCenter Server system or ESXi host using the vSphere Client,
2. Select the virtual machine,
3. On the *Summary* tab, select *Edit Settings...*,
4. In the *Hardware* tab, check entries of type:
 - Serial Port,
 - Parallel Port,
 - USB Controller,
 - CD/DVD drive,
 - Floppy drive,

for access to host devices and remove unneeded ones.

An alternative way of checking for host devices connected to virtual machines is to scan all vmx files on ESXi hosts for the following parameters:

- *floppyX.present*,

- *serialX.present*,
- *parallelX.present*,
- *usb.present*,
- *usb_xhci.present*,
- *ideX:Y.present*,

with *X* and *Y* being arbitrary numbers.

If all of these parameters are missing or have the value *false*, then there is no host device connected to the virtual machine. Otherwise, check if there is a strong reason for the virtual machine to access the host device and remove unneeded device access as described above.

To prevent a virtual machine user or process from disconnecting devices, follow these steps:

1. Log in to the vCenter Server system or ESXi host using the vSphere Client,
2. Select the virtual machine to change,
3. On the *Summary* tab, select *Edit Settings...*,
4. On the *Options* tab select *Advanced* → *General*,
5. Select *Configuration Parameters...*,
6. Add or edit the following configuration parameters, each with a value of *true*:
 - *isolation.device.connectable.disable*,
 - *isolation.device.edit.disable*.

Alternatively, the PowerCLI can be used to apply those settings:

```
Get-VM | New-AdvancedSetting
  -name "isolation.device.connectable.disable"
  -value $true

Get-VM | New-AdvancedSetting
  -name "isolation.device.edit.disable"
  -value $true
```

Revision history:

- 1.0: Measure created.

7.13 Restrict Import of Virtual Machines in Native Format

EVAL

mandatory

Measure M135939, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Virtual machine configuration data and virtual hard drives can be stored within native formats like VMX and VMDK. When importing such formats, the containing configuration is imported as well. Thus, already existing security measures might be circumvented by such formats. In worst case scenarios, an attacker may prepare a virtual machine to have host access and trick the operator of a vSphere installation into importing this manipulated machine. This allows the attacker full control over the host system.

Measure

Do not import virtual machines or virtual appliances in VMX/VMDK format.

Exception

This measure does not apply for machines being reimported from a secured backup storage where only authorized and trusted personnel has access to.

Implementation

Instead of using the VMX/VMDK format, use *Open Virtualization Format* (OVF) for importing virtual machines to the vSphere infrastructure.

If a virtual system is available only in VMX or VMDK format, it must be converted into OVF prior to its import. Before the first start of such virtual machines, its settings must be reviewed to avoid any direct hardware access being permitted to the VM.

Revision history:

- 1.0: Measure created.

7.14 Patching of Inactive Virtual Machines and Templates

EVAL

mandatory

Measure M135782, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Virtual machines may reside offline on a vSphere cluster or ESXi host for a long time. Also, templates of virtual machines can be created and used for the creation of new virtual machines.

Modern operating systems are a complex stack of different software layers that usually contain several hundred-thousand lines of code. It is very likely that such systems contain security relevant bugs. Typically, the process of bug discovering is of ongoing nature and not deterministic. Thus, missing patches or update in these offline virtual machines or the templates may pose a serious security risk.

Measure

Implement security updates and patches in a timely manner for the operating system and/or software of

- Virtual machines,
- Inactive virtual machines,
- Templates of virtual machines.

The measure **M135739 Siemens CERT Security Telegrams and Update Policy** gives you guidance how to receive security notifications for the components being used in your environment.

Exception

This measure may not be implemented, if there is a process which ensures that

- All templates of virtual machines are properly updated before instantiation,
- All inactive machines are properly updated before being connected to the production network, e.g., the Siemens Intranet.

Alternatively, a valid option is also the disposal of a virtual machine or template once a security update is available for it.

Implementation

Within the implementation time-frame of a security telegram

- Implement it on any affected running virtual machine,
- Resume/start any affected, inactive virtual machine and implement the security telegram,
- Create a virtual machine of any affected template, implement the security telegram and create a new template from the updated virtual machine.

Apply the same procedure for security updates and patches from vendors of software not supported by CERT security telegrams.

Revision history:

- 1.0: Measure created.

7.15 Snapshot Documentation and Removal

EVAL

mandatory

Measure M135311, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

Snapshots allow administrators and users of virtual machines to rollback to a secure stable systems state. However, this mechanism can also cause unforeseen and harmful side effects. With traditional, physical computing environments, systems are iteratively patched, updated and configured. Whenever an old snapshot is applied, the newest security relevant patches, updates and configuration changes within a virtual machine may be inadvertently reverted. The resulting system may violate security telegrams, run outdated software and reintroduce vulnerabilities.

Measure

Follow these rules for handling snapshots:

- Remove snapshots of virtual machines that are no longer needed,
- Remove snapshots older than 14 days,
- Before activating a snapshot of a virtual machine, check the snapshot for mandatory configuration changes. If there are mandatory updates or changes which have an implementation deadline in the past, then follow these steps:
 1. Change the configuration of the virtual machine in order to disconnect it from the Siemens network,
 2. Activate the snapshot,
 3. Apply all mandatory configuration changes, patches and updates according to the snapshot creation date and documentation,
 4. Reconnect the virtual machine to the network.

Implementation

Check your virtual machines for outdated snapshots in regular intervals. CERT recommends to check virtual machines for outdated snapshots prior to applying patches and updates.

If snapshots are used for a particular virtual machine, CERT recommends to make a snapshot after security relevant changes. This reduces the need for activation of older snapshots and subsequent offline-patching as described in this measure.

Revision history:

- 1.0: Measure created.

8 Miscellaneous

8.1 Secure Update Manager

EVAL

mandatory

Measure M135504, created on 2017-03-31. **EVAL** flag expires 2017-06-30.

Explanation

The VMware vSphere Update Manager can be used to download vendor patches and distribute those patches to the vCenter Server or ESXi hosts.

If the vSphere management network does not have access to the Internet to download updates and patches, then the Update Manager Download Service (UDMS) can be used on a different system connected to the Internet to retrieve the downloads. These downloads can then be made available to the Update Manager.

This behavior poses a potential attack vector to trigger the installation of malicious patches and updates. Thus, it must be ensured, that those updates and patches are downloaded from trustworthy sources. Furthermore, the downloads have to be protected against manipulation during the download and afterwards.

Measure

Use the following setup and configuration to secure the Update Manager:

- Either a path to a local media or an HTTPS-URLs must be configured as download source,
- If an HTTPS-URL is being used, it must be ensured that the HTTPS certificate is valid and owned by the supplier of the updates,
- Write access to the patch repository location must be limited to the user running UDMS/Update Manager.

Implementation

When adding new download sources, ensure that the sources are secured via HTTPS. Furthermore, the HTTPS certificate must be valid and owned by the supplier of the updates.

Check the permissions of the directory containing the Patch Repository Location of the download manager or the UDMS. Limit the permissions to allow write access only to the user running UDMS/Update Manager.

Revision history:

- 1.0: Measure created.

9 Checklist

An editable Security check sheet in Excel format can be found at

https://www.cert.siemens.com/rules/policy/CERT_VMware_vSphere6_Security_Check_Sheet.xls

Device Name: _____

Chapter No.	Measure No.	Measure	Done
General Security Principles			
3.1	M135365	Follow Siemens Information Security Framework	
3.2	M135290	Compliance with Corporate Password Policy	
3.3	M135739	Siemens CERT Security Telegrams and Update Policy	
3.4	M135517	Implement Relevant CERT Measure Plans	
3.5	M135404	Principle of Least Privilege	
3.6	M135451	Avoid Granting Privileges to Single Users	
3.7	M135278	Use Siemens PKI Certificates	
3.8	M135125	Protecting Physical Interfaces	
3.9	M135269	Secure Built-in Remote Management Interface	
3.10	M135319	Configure NTP Clients	
3.11	M135612	Enable Persistent Logging	
3.12	M135274	Prevent Resource Takeover	
General Network Security			
4.1	M135833	Separate Management and User Networks	
4.2	M135546	Secure vMotion Network Traffic	
4.3	M135449	Check Network Isolation at Regular Intervals	
4.4	M135550	Disable Native VLAN Feature for All Switches	
4.5	M135358	Disable Simple Network Management Protocol	

Chapter No.	Measure No.	Measure	Done
4.6	M135445	<i>Reject Forged Transmissions from Virtual Machines</i>	
4.7	M135894	<i>Disable Promiscuous Mode for Virtual Network Interfaces</i>	
vCenter Security			
5.1	M135363	<i>Enable Network File Copy Encryption</i>	
5.2	M135207	<i>Use Active Directory Service for Authentication</i>	
5.3	M135443	<i>Limit vCenter Server Network Connectivity</i>	
5.4	M135343	<i>Install a Dedicated vCenter Account</i>	
5.5	M135427	<i>Remove vSphere Administrator Privileges from Domain Admins</i>	
5.6	M135356	<i>Do Not Grant vSphere Access for Users of Virtual Machines</i>	
5.7	M135444	<i>Secure vCenter Single Sign On</i>	
ESXi Security			
6.1	M135165	<i>Enable lockdown mode</i>	
6.2	M135863	<i>Enable ESXi Firewall</i>	
6.3	M135413	<i>Control CIM-based Hardware Monitoring Tool Access</i>	
6.4	M135895	<i>Do Not Use the Root User</i>	
6.5	M135751	<i>Disable ESXi Privileges for AD Group "ESX Admins"</i>	
6.6	M135584	<i>Only Use Drivers from Trusted Sources</i>	
6.7	M135481	<i>Secure Storage Traffic</i>	
6.8	M135711	<i>Secure the ESXi Shell</i>	
6.9	M135770	<i>Disable Managed Object Browser</i>	
6.10	M135825	<i>Centralized Collection of Core Dumps</i>	
6.11	M135342	<i>Prevent Unintended Usage of dvfilter API</i>	

Chapter No.	Measure No.	Measure	Done
Virtual Machine Security			
7.1	M135160	<i>Disable Copy-and-Paste and Drag-and-Drop Operations</i>	
7.2	M135685	<i>Disable Shared Console Sessions</i>	
7.3	M135835	<i>Disable Unused Display Features</i>	
7.4	M135621	<i>Disable Unity Features</i>	
7.5	M135565	<i>Disable Unexposed VMX Features</i>	
7.6	M135674	<i>Disable VIX Messages from Virtual Machines</i>	
7.7	M135702	<i>Limit Host Information Sharing</i>	
7.8	M135327	<i>Reject MAC Address Changes by Virtual Machines</i>	
7.9	M135793	<i>Limit Information Messages Stores Within VMX Files</i>	
7.10	M135736	<i>Limit Log File Numbers and Size for Virtual Machines</i>	
7.11	M135640	<i>Prevent Virtual Disk Operations</i>	
7.12	M135956	<i>Secure Connected Devices</i>	
7.13	M135939	<i>Restrict Import of Virtual Machines in Native Format</i>	
7.14	M135782	<i>Patching of Inactive Virtual Machines and Templates</i>	
7.15	M135311	<i>Snapshot Documentation and Removal</i>	
Miscellaneous			
8.1	M135504	<i>Secure Update Manager</i>	

References

- [1] Siemens GS IT ISEC, *ISEC Technical Standard: Secure Network Topologies - Network Zone Types*, available at <https://cio.siemens.com/cms/it/en/isec/regulations/Pages/isectechnicalstandards.aspx>
- [2] Siemens GS IT ISEC, *Siemens Information Security Framework*, available at <http://intranet.siemens.com/ISECFramework>
- [3] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Access Control*, available at <https://inspire.siemens.com>
- [4] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Asset Management*, available at <https://inspire.siemens.com>
- [5] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Cryptography*, available at <https://inspire.siemens.com>
- [6] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Operations Security*, available at <https://inspire.siemens.com>
- [7] Siemens CERT, *InfoSec Rules / Mandatory documents*, available at <https://www.cert.siemens.com/rules>
- [8] Siemens CERT, *Security Measure Plan for Microsoft Windows Servers*, available at <https://www.cert.siemens.com/rules/windows>
- [9] Siemens CERT, *Security Measure Plan for Microsoft Windows Workstations*, available at <https://www.cert.siemens.com/rules/windows>
- [10] Siemens CERT, *Security Measure Plan for UNIX and Linux Operating Systems*, available at https://www.cert.siemens.com/rules/policy/CERT_UNIX_Linux_Measure_Plan.pdf
- [11] Siemens CERT, *Security Measure Plans for Microsoft SQL Servers*, available at <https://www.cert.siemens.com/rules/dbms>
- [12] Siemens CERT, *Security Measure Plans for Network Devices*, available at <https://www.cert.siemens.com/rules/net>
- [13] Siemens CERT, *Security Measure Plans for Oracle RDBMS*, available at <https://www.cert.siemens.com/rules/dbms>
- [14] Siemens GM SEC, *Siemens Circular No. 156: "Risk-based Asset Classification and Protection Process"*, 23 September 2016, Version 1.1, available at https://circulars.siemens.com/documents/circulardownload.aspx?id=sc_156.pdf